

# Análise do protocolo HTTPS

Neste guião iremos analisar a comunicação segura e a distribuição de chaves públicas num protocolo muito frequente na Internet: HTTPS. Para isso necessita de usar uma VM com um Linux baseado em Debian e o navegador Firefox. Elabore um relatório sobre o trabalho, que inclua as respostas às questões que vão sendo colocadas e as capturas de ecrã que vai fazendo, e submeta-o na área da disciplina no elearning.

## 1 Versões de TLS

O protocolo HTTPS é o protocolo HTTP sobre o protocolo SSL/TLS. Atualmente a utilização do protocolo SSL já não é recomendada. Em relação ao protocolo TLS, apenas é recomendada a utilização das versões 1.2 e 1.3.

### 1.1 Verificar as versões de TLS suportadas pelo browser

No browser Firefox pode verificar quais as versões de TLS que ele está configurado para usar, acedendo ao URL `about:config`. Depois de entrar, deve procurar por `security.tls.version.m`, e deve observar as entradas ilustradas na figura seguinte.

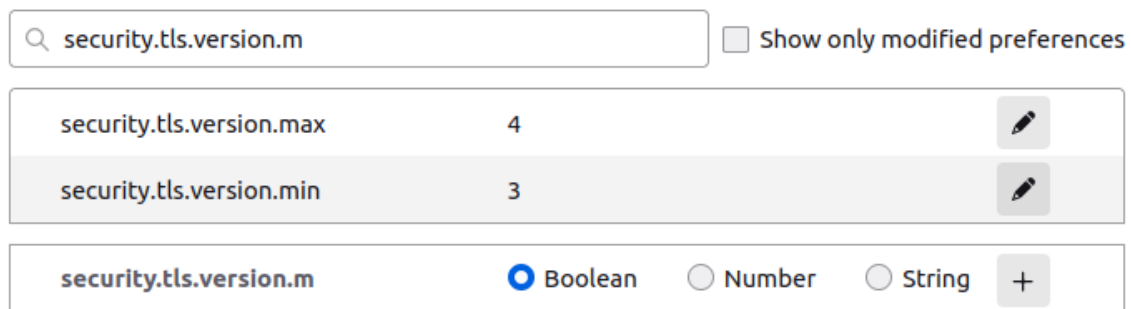


Figura 1: Versões do TLS suportadas num browser Firefox.

O significado dos valores possíveis na janela acima são os seguintes:

- 1 => TLS 1.0
- 2 => TLS 1.1
- 3 => TLS 1.2
- 4 => TLS 1.3

Para que versões de TLS está configurado o browser que usa diariamente? Como provavelmente não usa o Firefox, pesquise como obter esta informação no browser que normalmente usa.

## 1.2 Versões de TLS num servidor Web

Existem serviços na Web que permitem analisar a configuração do SSL/TLS em servidores Web. Um desses exemplos é o SSLTest que se encontra no site da Qualys SSL Labs, que pode encontrar em <https://www.ssllabs.com/ssltest>. Aceda a esse site.

Este serviço faz a análise da configuração do SSL/TLS nos sites que o utilizador indicar, e classifica-os numa escala de F (pior) a A (melhor), sendo que as de excecional qualidade recebem um A+. Pode ainda encontrar as classificações M, quando o domínio do site não coincide com o Common Name (CN) no certificado, e T, quando o certificado não é confiável.

Na página inicial, além de permitir que o utilizador indique um site que pretende analisar, mostra os sites analisados recentemente e que obtiveram as melhores e as piores classificações. Clique num site que esteja classificado com um dos melhores analisados recentemente. Veja a classificação global do site (Overall rating), bem como as classificações para os certificados (Certificates), para os protocolos suportados (Protocol support), negociação de chaves (key exchange) e robustez das cifras (cipher strength) que compõem a cipher suite.

Se o site não recebeu pelo menos a classificação global de A, o motivo é indicado junto à classificação. Concorde com a razão indicada para não obter a classificação de A? Porquê? Faça uma captura de ecrã mostrando a informação do site.

Se andar um pouco para baixo na página, encontra informação sobre o certificado #1. Veja essa informação. Pode analisar os caminhos de certificação (certification Paths). Expand a vista dos caminhos de certificação caso seja necessário. O que pode dizer sobre os caminhos de certificação apresentados?

Ande mais para baixo na página, para a área de Configuração (Configuration). Veja a lista de protocolos suportados e não suportados. Para aumentar a segurança do site, que protocolos já não deveriam ser suportados?

Regresse à página inicial e selecione um site que esteja indicado como um dos recentes com prior classificação. Analise o sumário, a informação sobre certificados, configuração e cipher suites. Concorde com a classificação atribuída? Porquê?

Analise um sítio na Web à sua escolha, que use o protocolo HTTPS. Faça uma captura da página com o resultado, analise o resultado e indique a seguinte informação:

- Qual a classificação obtida?
- Quais as versões de SLS/TLS suportadas?
- Quantas cipher suites classificadas como fracas são suportadas?
- Tem um certificado válido?
  - Qual a entidade emissora?
  - Qual o prazo de validade?
- Concorda com a classificação atribuída ao servidor? Porquê?

### 1.3 Ferramentas adicionais

Existe um conjunto adicional de sites que permitem fazer online a verificação da configuração de sites HTTPS, além de outras verificações. Exemplos destes sites são:

- <https://webcheck.pt/pt/>
- <https://www.hardenize.com/>
- <https://www.immuniweb.com/>

Aceda a cada um destes sites e indique em que diferem do SSLTest que usou no ponto anterior

Existe também uma ferramenta que permite fazer a análise local da configuração de um servidor web. Trata-se da ferramenta *testssl*, que é um script que vai analisar uma série de parâmetros da configuração do servidor Web. Em ambiente Linux pode instalá-la a partir dos repositórios (comando `sudo`). Faça a instalação do *testssl* na máquina onde criou o servidor web do trabalho anterior, analise a configuração do servidor. O que conclui? O que pode melhorar?

## 2 Observação do tráfego HTTPS

Pretende-se observar e analisar o tráfego HTTPS, isto é o tráfego trocado entre um browser e um servidor Web usando o protocolo HTTPS.

## 2.1 Captura e análise do tráfego HTTPS cifrado

No seu browser, limpe a cache e outros dados de site que ele possa ter guardados (no Firefox, pode fazer esta operação na janela “Privacy & Security” que pode aceder no menu Edit->Settings). De seguida, feche o browser.

Na sua máquina inicie uma captura de tráfego usando o Wireshark.

Aceda ao site da entidade que analisou na secção 1.2. Depois de abrir a página inicial, termine a captura no Wireshark.

No Wireshark, pretende-se analisar os pacotes dos protocolos que foram usados para descarregar a página inicial do site a que acedeu. Comece por aplicar um filtro para mostrar apenas os pacotes DNS. Procure qual o endereço IP do site a que acedeu e indique-o no relatório. Faça também uma captura do ecrã do Wireshark mostrando o pacote DNS que indica o endereço IP do site a que acedeu.

Usando esse endereço IP, aplique um filtro para observar apenas os pacotes trocados com o site. Qual o filtro que aplicou?

Analise os pacotes trocados com esse site e indique qual a versão do protocolo TLS que foi usada. Apresente uma captura do ecrã do wireshark mostrando essa informação.

Abra um dos pacotes “Application Data” e faça uma captura de imagem que mostre, na parte do “Transport Layer Security”, os dados cifrados.

## 2.2 Captura, decifra e análise do tráfego

Apesar de o tráfego HTTP ser cifrado, é possível decifrar e observar o tráfego. Para isso é necessário ter acesso às chaves usadas nas sessões TLS. Para isso, temos de dizer ao Firefox para guardar o material criptográfico num ficheiro por nós especificado.

Abra uma linha de comando numa máquina Linux com a distribuição Debian ou uma sua variante, como é o caso do Ubuntu e do Kali. Edite o ficheiro .bashrc que se encontra na sua pasta local (home). No final do ficheiro, adicione a seguinte linha:

```
export SSLKEYLOGFILE=~/.chaves_ssl.txt
```

Guarde o ficheiro e feche essa linha de comando.

Abra uma nova linha de comando e execute o seguinte comando para ver o local onde o material criptográfico vai ser guardado:

```
echo $SSLKEYLOGFILE
```

Faça uma captura de imagem da linha de comando com a resposta ao comando anterior.

Nessa linha de comando, abra o Firefox, usando o comando:

```
firefox&
```

Inicie uma nova captura no Wireshark. No seu browser, aceda novamente ao site que analisou nas secções anteriores. Quando a página tiver terminado de carregar, termine a captura. Identifique o pacote “Client Hello” com que o browser iniciou o estabelecimento da ligação segura com o servidor, clique sobre ele com o botão do lado direito do rato e selecione a opção “Follow → TLS Stream” para confirmar que não consegue ver nada por a comunicação estar cifrada. Faça uma captura de ecrã.

Agora, indique o ficheiro de chaves ao Wireshark, abrindo a janela de preferências (menu “Edit → Preferences”), nesta seleccionado o protocolo TLS e indicando o ficheiro na última entrada da janela, “(re)-Master-Secret log filename”.

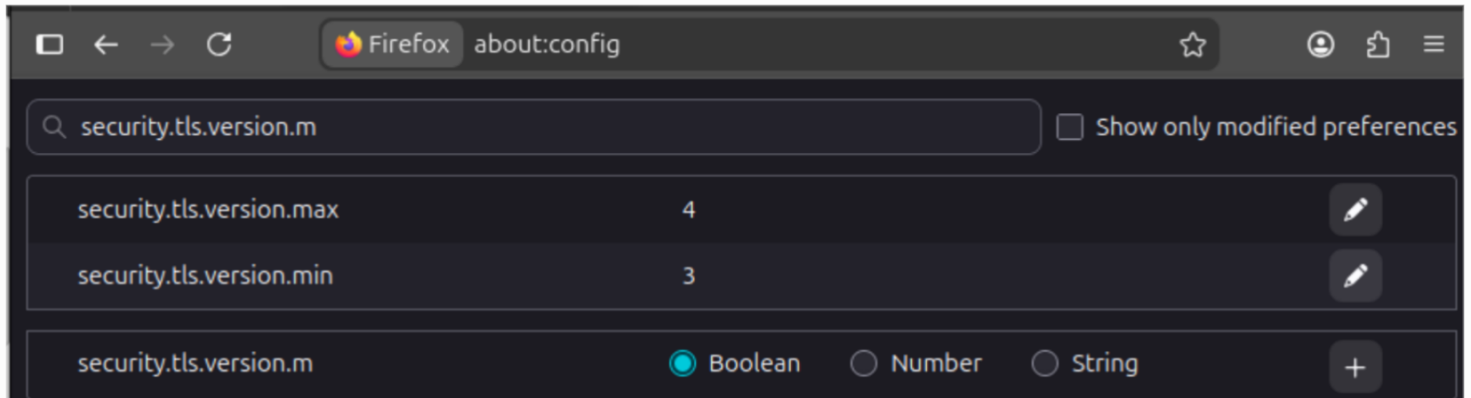
Depois de indicar o ficheiro, volte a clicar com o botão do lado direito do rato sobre o pacote “Client Hello” e a seleccionar a opção “Follow → TLS Stream” e poderá observar os pacotes com o código da página Web a que acedeu no browser. Faça uma captura de ecrã que mostre esses pacotes.

### 3 Conclusão

Prepare um relatório sobre o trabalho, que inclua a respostas às perguntas e capturas de imagem que evidenciem a realização dos vários passos.

# 1. Versões de TLS

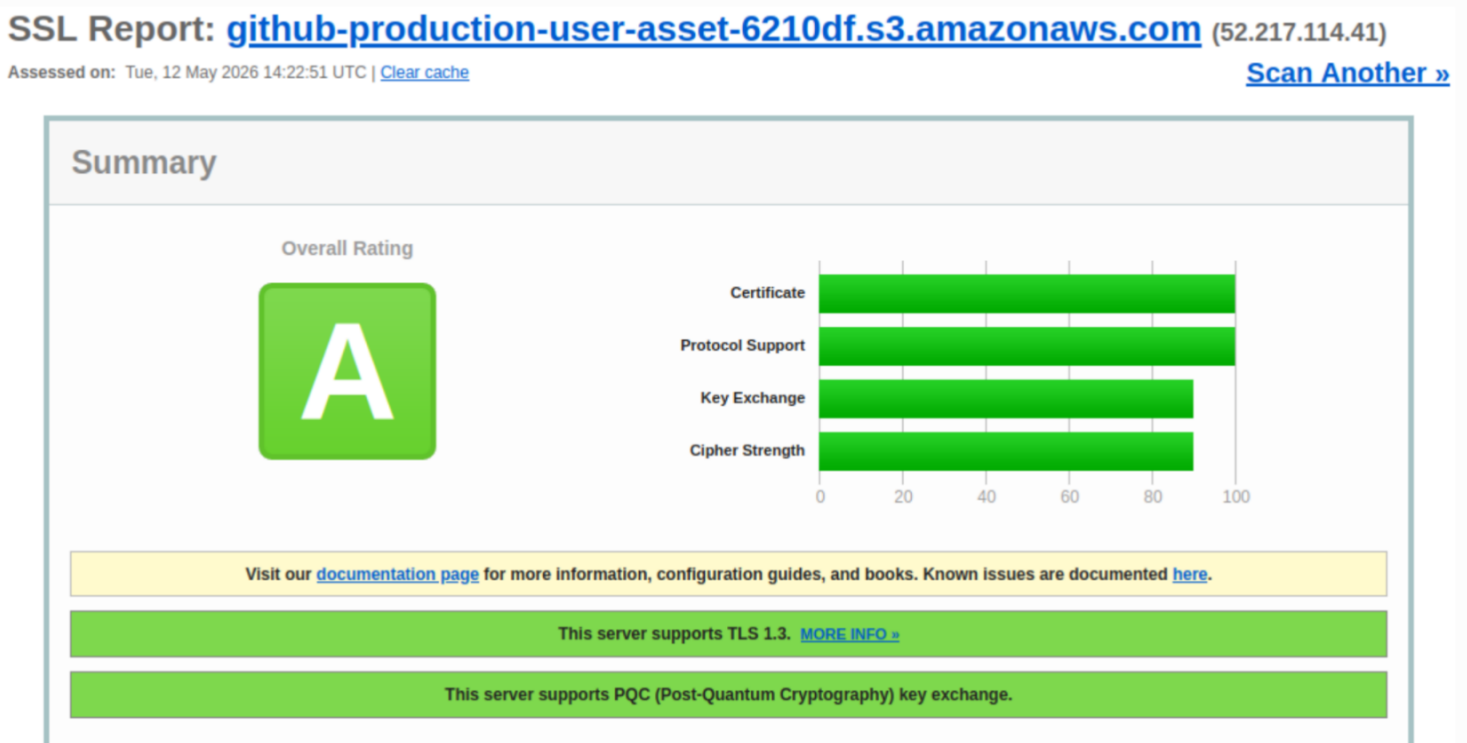
## 1.1 Verificar as versões de TLS suportadas pelo browser :



O browser suporta as seguintes versões de TLS:

- 3 => TLS 1.2
- 4 => TLS 1.3

## 1.2 Versões de TLS num servidor Web :



Certificate #1: RSA 2048 bits (SHA256withRSA)



Server Key and Certificate #1



|                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|--------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Subject                  | s3.amazonaws.com<br>Fingerprint SHA256: 7eb42635dc32bc97760c383ee186339aacea239e156b98d741c7912671436<br>Pin SHA256: iQ5PRP4LYp2a+3iFj2mL3GPE6PhOJrWwubEtKc=                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Common names             | s3.amazonaws.com                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Alternative names        | s3.amazonaws.com *s3.amazonaws.com *s3-accesspoint.us-east-1.amazonaws.com *s3-control-us-east-1.amazonaws.com s3.dualstack.us-east-1.amazonaws.com *s3-deprecated.us-east-1.amazonaws.com s3-control.dualstack.us-east-1.amazonaws.com *s3-external-2.amazonaws.com s3.us-east-1.amazonaws.com *s3-accesspoint.dualstack.us-east-1.amazonaws.com *s3.us-east-1.amazonaws.com *s3-external-1.amazonaws.com *s3.dualstack.us-east-1.amazonaws.com s3-external-2.amazonaws.com s3-control.us-east-1.amazonaws.com s3-external-1.amazonaws.com s3-deprecated.us-east-1.amazonaws.com *s3-control.dualstack.us-east-1.amazonaws.com |
| Serial Number            | 07363a70568ccf5937852e409c4a1dee                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Valid from               | Tue, 18 Nov 2025 00:00:00 UTC                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Valid until              | Fri, 06 Nov 2026 23:59:59 UTC (expires in 5 months and 25 days)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Key                      | RSA 2048 bits (e 65537)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Weak key (Debian)        | No                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Issuer                   | Amazon RSA 2048 M04<br>AIA: http://crl.r2m04.amazonaws.com/2m04.cer                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Signature algorithm      | SHA256withRSA                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Extended Validation      | No                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Certificate Transparency | Yes (certificate)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| OCSP Must Staple         | No                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Revocation information   | CRL, OCSP<br>CRL: http://crl.r2m04.amazonaws.com/2m04.crl<br>OCSP: http://ocsp.r2m04.amazonaws.com                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Revocation status        | Good (not revoked)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| DNS CAA                  | No (more info)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Trusted                  | Yes<br>Mozilla Apple Android Java Windows                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |



Cipher Suites

|                                                      |                                            |     |
|------------------------------------------------------|--------------------------------------------|-----|
| # TLS 1.3 (suites in server-preferred order)         |                                            |     |
| TLS_AES_128_GCM_SHA256 (0x1301)                      | X25519MLKEM768 (eq. 3072 bits RSA) FS      | 128 |
| TLS_AES_256_GCM_SHA384 (0x1302)                      | X25519MLKEM768 (eq. 3072 bits RSA) FS      | 256 |
| TLS_CHACHA20_POLY1305_SHA256 (0x1303)                | X25519MLKEM768 (eq. 3072 bits RSA) FS      | 256 |
| # TLS 1.2 (suites in server-preferred order)         |                                            |     |
| TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)       | ECDH secp256r1 (eq. 3072 bits RSA) FS      | 128 |
| TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)       | ECDH secp256r1 (eq. 3072 bits RSA) FS      | 256 |
| TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca8) | ECDH secp256r1 (eq. 3072 bits RSA) FS      | 256 |
| TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)          | ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK | 128 |
| TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)       | ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK | 128 |
| TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)          | ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK | 256 |
| TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)       | ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK | 256 |
| TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c)               | WEAK                                       | 128 |
| TLS_RSA_WITH_AES_256_GCM_SHA384 (0x9d)               | WEAK                                       | 256 |
| TLS_RSA_WITH_AES_128_CBC_SHA (0x2f)                  | WEAK                                       | 128 |
| TLS_RSA_WITH_AES_128_CBC_SHA256 (0x3c)               | WEAK                                       | 128 |
| TLS_RSA_WITH_AES_256_CBC_SHA (0x35)                  | WEAK                                       | 256 |
| TLS_RSA_WITH_AES_256_CBC_SHA256 (0x3d)               | WEAK                                       | 256 |



Protocol Details

|                                              |                                              |
|----------------------------------------------|----------------------------------------------|
| Secure Renegotiation                         | Supported                                    |
| Secure Client-Initiated Renegotiation        | No                                           |
| Insecure Client-Initiated Renegotiation      | No                                           |
| BEAST attack                                 | Mitigated server-side (more info)            |
| POODLE (SSLv3)                               | No, SSL 3 not supported (more info)          |
| POODLE (TLS)                                 | No (more info)                               |
| Zombie POODLE                                | No (more info) TLS 1.2: 0xc013               |
| GOLDENDOODLE                                 | No (more info) TLS 1.2: 0xc013               |
| OpenSSL 0-Length                             | No (more info) TLS 1.2: 0xc013               |
| Sleeping POODLE                              | No (more info) TLS 1.2: 0xc013               |
| Downgrade attack prevention                  | Yes, TLS_FALLBACK_SCSV supported (more info) |
| SSL/TLS compression                          | No                                           |
| RC4                                          | No                                           |
| Heartbeat (extension)                        | No                                           |
| Heartbleed (vulnerability)                   | No (more info)                               |
| Ticketbleed (vulnerability)                  | No (more info)                               |
| OpenSSL CCS vuln. (CVE-2014-0224)            | No (more info)                               |
| OpenSSL Padding Oracle vuln. (CVE-2016-2107) | No (more info)                               |
| ROBOT (vulnerability)                        | No (more info)                               |
| Forward Secrecy                              | Yes (with most browsers) ROBUST (more info)  |
| ALPN                                         | Yes http/1.1                                 |
| NPN                                          | No                                           |
| Session resumption (caching)                 | No (IDs assigned but not accepted)           |
| Session resumption (tickets)                 | No                                           |
| OCSP stapling                                | No                                           |
| Strict Transport Security (HSTS)             | No                                           |
| HSTS Preloading                              | Not in: Chrome Edge Firefox IE               |
| Public Key Pinning (HPKP)                    | No (more info)                               |